

Access Control Policy

IT-04 | Version 1.0 | Effective 01 September 2026

Owner: IT & Security | Applies to employees and contractors

Fictional company policy for RAG training and evaluation. All .example addresses are placeholders; these are not live services.

1. Purpose and principles

Give each employee or contractor only the access needed for assigned work. All human users receive individual accounts. Shared human accounts are prohibited. Application permissions are separate from VPN eligibility; connection to the VPN does not authorize access to every system.

2. Request and approval

Submit a ticket at <https://support.northstar.example> naming the system, requested role, business reason, start date and end date if temporary. The line manager and system owner must approve before IT provisions access. The requester cannot approve their own request. IT records approval and the actual permissions in the ticket.

3. Standard and sensitive roles

Read-only access is the default when it satisfies the work need. Editing, export and administrative rights must be explicitly requested. Access to payroll, production administration or bulk customer-data exports additionally requires Security approval. IT targets fulfillment of ordinary requests within 2 business days after all approvals; urgent incident access uses the emergency procedure below.

4. Temporary and contractor access

Temporary project permissions expire after no more than 30 days. Contractor accounts and VPN entitlements expire after no more than 90 days and require a named employee sponsor. For a contractor assigned a temporary project role, both limits apply: the project role expires within 30 days even if the account remains active. Renewals require fresh approval before expiry.

Access Control Policy

Procedures and responsibilities

5. Privileged access

Use a separate administrator account for privileged tasks and the normal account for everyday work. Privileged sign-ins require a hardware security key. Local administrator elevation on a laptop expires after no more than 8 hours. Production administrator roles require manager, system owner and Security approval, with an explicit end date and a maximum grant of 30 days before renewal.

6. Role changes and departures

The manager submits role changes before the effective date. IT removes permissions no longer needed within 1 business day of that date, then provisions new permissions only after approval. HR supplies the departure date and exact time. IT disables the account and revokes sessions at that time; for involuntary departures, HR and Security coordinate immediate removal at the agreed notification time. Device return follows IT-02 and may occur later than account removal.

7. Reviews and emergency access

System owners review access every 90 days. IT removes unneeded access within 2 business days after the review decision. For an active security incident, the Security incident lead may authorize emergency access in a ticket for up to 4 hours. All actions are logged; the system owner and Security review use within 1 business day. Extensions require a new approval.

8. Service accounts and exceptions

Every service account needs a named owner, documented purpose and minimum permissions. Its owner reviews access every 90 days; secret rotation follows IT-01. Exceptions need written Security approval, an owner and an expiry of no more than 30 days. Exceptions cannot permit shared human accounts or self-approval.